

RESOLUTION FOR ARCHIVING OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following:

FACTS

FIRST: On December 5, 2022, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection to initiate the preliminary investigation proceedings referred to in Article 67 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD) to investigate the GALICIAN HEALTH SERVICE (hereinafter, SERGAS) in relation to the following facts:

As a consequence of the complaint with entry registration number REGAGE22e00051233319, this Agency was informed of an alleged breach of data protection regulations by the reported entity concerning the modules of special custody, in accordance with the provisions of Articles 16 and 17 of Decree 29/2009, of February 5, which regulates the use and access to electronic medical records. These articles establish that "through the IANUS system, mechanisms will be progressively established that allow the patient or user to determine a module or modules of clinical information that may contain those data considered to be of special custody or intimacy in the areas of genetics, sexuality and reproduction, psychiatry, organ transplantation, infectious diseases that may harm their social or work life, as well as data related to domestic violence," and that "the professionals who, in accordance with their functions, need to access the data of modules of special custody will be warned by the IANUS system of this circumstance, so that they indicate the reason for access, exercise extreme caution in its handling, and incorporate within the corresponding modules any new data that may be generated. In the access log, those corresponding to special custody data will be singled out, which will allow for specific audits to be carried out."

SECOND: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation proceedings to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following aspects:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/11

Modules of Special Custody: SERGAS states that all clinical information is stored or consolidated in IANUS and that data to which Article 16 of RD 29/2009 may refer, and therefore considered to be of special custody or intimacy, may be contained in modules that integrate its information in IANUS (for example, in laboratory information management systems (LIS), in epidemiological surveillance systems, etc.). In addition to the information integrated into IANUS, these modules have functionality with independent and exclusive access by the involved personnel (specialist doctors, epidemiologists). Within IANUS, and in accordance with the provisions of Article 15 of Law 3/2001, of May 28, regulating informed consent and the clinical history of patients, "This clinical history will accumulate all clinical information generated in each care episode and will integrate the different episodes of the patient," all systems of origin of clinical information are integrated to present the information in a coherent and integrated manner.

Furthermore, SERGAS includes in its response:

The information that may be included in modules of special custody and its method of inclusion is established by the person in charge of the Consellería de Sanidade as responsible for such processing. They will be the ones to establish the structure, definition, functioning, or mechanisms for enabling the modules of special custody.

Patients/users may determine the inclusion of information from their clinical history in modules of special custody through the electronic headquarters of the Xunta de Galicia, using procedure PR004A, Electronic submission of requests, writings, and communications that do not have a specific electronic system or a standardized electronic model, given that there is no specific procedure established and no standardized electronic model is available.

(<https://sede.xunta.gal/detalle-procedemento?codtram=PR004A>).

1. Definition

The IANUS clinical history system began its implementation in 2004, and when Decree 29/2009 came into force, the Consellería de Sanidade established that the most effective protection mechanism was the integration of all clinical history information into a module of special custody at the moment the patient so determined.

Since then, the Consellería de Sanidade has confirmed the need for the integration of all care information into a single container. For example, during a certain time interval, restrictions were implemented for the integration of genetic information from any IANUS patient that had to be lifted due to the care problems generated by the loss of integrity of the information in the communication process between the internal genetic platforms of the Public Health System of Galicia and IANUS.

This reflection could be extended to any other information mentioned in reference to the modules of special custody.

There is also another added difficulty, which is evident in processes such as voluntary interruptions of pregnancy or fertility treatments carried out outside the public health system: episodes that are NOT recorded in the IANUS clinical histories are referred to by the patients themselves in subsequent instances.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/11

assistance regarding processes other than those of healthcare professionals when they conduct the anamnesis and these are collected due to their clinical relevance in the new ongoing process. From that point on, they are registered in IANUS, and it becomes tremendously complex, even at times impossible, to disentangle such references from the care provided in healthcare episodes that must be preserved, hindering the exercise of rights to rectification or deletion.

In summary, the Consellería de Sanidade, as the data controller, has reached an increasingly reinforced conclusion regarding the necessity to unify all information of each patient in IANUS and the significant risks that any type of healthcare segmentation may entail.

Therefore, the initial operation of the special custody modules is maintained, and what the patient can determine within the special custody modules is the protection of their entire medical history.

The authorizations for access are nominal. By default, no one can access the information contained in the medical history/module, and if necessary for the healthcare of the patient, the management of the corresponding area will enable access for the involved professionals.

In the absence of such authorization for access to these histories/modules, when a user attempts to do so, the system alerts to the existence of protection mechanisms, denies access, and indicates that express authorization is required. This access is always linked to the healthcare activity.

Regarding the other cases that arise, we can rule out secondary uses such as access for evaluation, accreditation, healthcare planning, teaching, research, scientific publications, or statistical or epidemiological purposes.

In the case of access for inspection or judicial purposes, we have no record of such occurrences, and they should also be expressly authorized to carry out the access. In the hypothetical case that we receive such a request in the future, duly justified, we believe we would have a legal obligation to address it.

We can make the above assertions with such certainty because, to date, only 3 individuals have determined their inclusion. One of them passed away 12 years ago, and another is no longer a subject of healthcare provision in the SPSG (Public Health System of Galicia), so in reality, only one patient

currently covered has this active protection.

Not only have no requests for inclusion in the module been received, but since the protocolization of the rights in data protection, only one communication regarding these modules has been received, requesting information about their operation, but without indicating a desire to determine their inclusion.

2. Information to Citizens

Regarding information, it is available to all citizens at <https://www.sergas.gal/protecciondatos> and on the electronic headquarters of the Xunta de Galicia

https://www.xunta.gal/informacion-xeral-proteccion-datos?langId=es_ES. The processing activity that encompasses IANUS is "Management of Medical History and Healthcare Activity," whose purpose is "Data from the medical history of the C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es 4/11

sick for the follow-up of this, management of healthcare activity, financial management, billing, pharmaceutical provision, orthopedic provision, healthcare transportation, addition, [...]"

The documents provided to citizens also include references to these treatment information channels. There is no prioritization among the rights granted to citizens regarding data protection, specifically concerning information about any one of them. Therefore, no specific informational action is taken regarding the existence of these modules (special custody modules).

Another characteristic of the healthcare system is its accessibility. We have 500 specific points of attention for citizens, in addition to the informational tasks that healthcare professionals (doctors, nursing staff...) perform during the course of the more than 30 million clinical acts that are carried out each year in the Public Health System of Galicia.

3. Procedure

Regarding the description of the procedure followed by the Consellería de Sanidade when a patient/user requests that information from their clinical history be included in a special custody module, we reiterate that 3 requests have been received, and given that volume, no specific procedure has been carried out; instead, the same procedure applicable to any other right concerning data protection would be applied, as indicated at <https://www.xunta.gal/exercicio-de-dereitos>.

In the event of exercising this right, the steps we would follow after receiving the request via registration would be:

1. Response to the request informing them of the possible healthcare risks that may arise from the limitations in accessing the EHR by enabling said module.
2. In the event that the patient indicates that they understand the risks, the information would be requested, among other information, authorization from the professionals, etc.
3. The configuration of the user for the special custody module would be carried out by an administrator with user configuration privileges.

1. Access to Information

Identification is of dual factor: user and password from the Active Directory plus a signature with a certificate stored on a secure device (cryptographic card).

Access to the special custody module is through the general access module to the IANUS system; that is, it is not to a specific module but through IANUS, where access to patient sets is enabled based on the privileges assigned to each user.

Once a user has accessed IANUS, they CANNOT consult the data of a patient in a special custody module unless they have specific permission for that. In fact, when searching for a user included in the special custody module, only authorized professionals will see their data; the rest of the professionals will not receive any response regarding this. Once accessed, they will have access to all the information contained in the clinical history. We reiterate, as in the previous report we sent regarding this file, that experience shows us the necessity for access to EHRs to be complete to ensure adequate healthcare for patients.

Since the special custody module follows the general access rules of IANUS, the same control measures established by IANUS for access records apply. All accesses made to the EHRs are registered, stored, and evaluated. It is evident that access to a special custody module would draw

attention and would be subject to special scrutiny, but given that there is only one patient and only one authorized professional, accesses are anecdotal within the global set of accesses.

2. Security Measures

SERGAS states that the highest security measures are applied to all activities carried out in IANUS, both through access mechanisms and through activity logs.

These measures have not been altered following the definition of special custody modules by Decree 29/2009.

3. Operation

The functionality of IANUS that restricts access to the EHRs of patients under special custody is called "VIP Patients."

The configuration of these patients is carried out from the administration module of IANUS through a specific permission and can be configured at the professional level or at the patient level.

1. At the professional level

From the user administration (professionals) of IANUS, there is a section to assign "VIP Patients" to a specific professional. When a patient is assigned as a VIP patient linked to a professional, only those professionals assigned to them will be able to access their history.

2. At the patient level

From the administration of IANUS, the same configuration can also be made, but starting from the patient. That is, the "VIP Patient" is searched for, and subsequently, the professionals to whom access to their history is desired can be managed.

After selecting the patient, professionals can be added or removed.

The response of IANUS when accessing the EHR of a patient under special custody is as follows:

3. When an authorized professional accesses from IANUS to the EHR of a patient under special custody, the patient's clinical history loads correctly.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/11

4. When an unauthorized professional attempts to access a patient's HCE (Electronic Health Record) with special custody from IANUS, the patient's clinical history is not loaded, and the user is redirected back to the patient search. This behavior (redirection to the patient search) is maintained even when accessing the patient's HCE through other means (such as a worklist with scheduled patients in a consultation, for example). That is to say, even if a patient is listed in a professional's agenda, if that patient has a history of restricted access and that professional does not have access configured for that history, the patient's history will not be loaded. Screenshots are provided that reflect the above with data extracted from the pre-production environment and do not correspond to real data of any interested party.

Regarding the access logs to HCEs with special custody:

Access logs are included in the LOG RA (Access Log) of the application.

5. When an authorized professional attempts to access the patient's HCE, a record of their access is made: "Transaction Execution: ACCESS_HISTORY"

6. When an unauthorized professional attempts to access the HCE of a patient with restricted access, a record of the access cancellation is made: "Transaction Execution: CANCELLED_ACCESS_HISTORY"

The files LOG_RA_Autorizado.txt and LOG_RA_NOAutorizado.txt are provided with the complete record corresponding to the tests conducted and presented in the aforementioned screenshots.

LEGAL GROUNDS

I

Competence

In accordance with the functions conferred to each supervisory authority by Article 57.1 a), f) and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in

Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative actions.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/11

II

Security of processing

Article 32 of the GDPR stipulates the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular account shall be taken of the risks presented by the processing, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless he or she is required to do so by Union or Member State law."

III

Principles relating to processing

Letter f) of Article 5.1 of the GDPR advocates:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

8/11

IV

Conclusion

In the case at hand, the complaint states: “that SERGAS is not applying in IANUS Decree 29/2009, of February 5, which regulates the use and access to the electronic medical record regarding the Modules of special custody and requests that professionals receive such a warning about access whenever they access modules of special custody.”

Well, IANUS is the main information system of the Electronic Medical Record (hereinafter, EMR) of the Servizo Galego de Saúde (SERGAS).

The main functionalities of the program include real-time access to patients' health data, the integration of all professionals in care, continuity of care, or the agility in procedures due to reduced bureaucracy, the incorporation of electronic prescriptions, and the possibility of connection between pharmacies and centers.

Therefore, IANUS integrates all clinical and administrative information of patients who have had any relationship with SERGAS.

Part of the information is recorded in IANUS itself, and another part is recorded in the various information systems used by SERGAS, structuring it under a standardized model of EMR common to all patients.

The roles/users who have access to the EMR of SERGAS are outlined in Decree 29/2009, of February 5, which regulates the use and access to the electronic medical record.

Access is made through a double factor: the card with a certificate for recognized signature and a combination of username and password with which it verifies the access profile. Access logs are consolidated in a complex data analysis system (SIAC) that serves as a basis for auditing, inspection, and control tasks of the accesses made.

IANUS began its implementation in 2004, and when Decree 29/2009 came into force (in its articles 16 and 17 refers to the modules of special custody), it was established by the Consellería de Sanidade that the most effective protection mechanism was the integration of all clinical history information into a module of special custody at the moment the patient so determined.

The Consellería de Sanidade has reached an increasingly reinforced conclusion of the need to unify all information of each patient in IANUS to ensure adequate healthcare for patients, due to the risks that any type of health segmentation may pose. Therefore, it maintains the initial operation of the modules of special custody: what the patient can determine within the modules of special custody is the protection of their entire clinical history.

It should be noted that access to a module of special custody is through the general access module to the IANUS system, and the authorizations for access to the modules of special custody are nominal. By default, no one can access the information.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/11

contained in the medical record/special custody module and, if necessary for the patient's healthcare, the management of the corresponding area will enable access for the involved professionals. Once accessed, they will have access to all the information contained in the medical record.

Furthermore, in the event that the user does not have such authorization for access to these medical records/special custody modules, when attempting to access, the system alerts to the existence of protection mechanisms, denies access, and indicates that express authorization is required. This access is always linked to healthcare activity.

Since the special custody module follows the general access rules of IANUS, the same control measures established by IANUS for access records apply. All accesses made to the electronic health records (EHR) are registered, stored, and evaluated.

On the other hand, patients/users may determine the inclusion of information from their medical record in special custody modules through the electronic headquarters of the Xunta de Galicia, using procedure PR004A, Electronic submission of requests, documents, and communications that do not contain a specific electronic system or a standardized electronic model. SERGAS informs that so far

only three requests have been received and that given this volume, no specific procedure has been established and there is no standardized model, but the same procedure as for any other right regarding data protection would apply, as indicated at <https://www.xunta.gal/exercicio-de-dereitos>. It is worth noting the proactive action of SERGAS regarding these modules. Notwithstanding their regulation, they saw clear risks for the patient in the segmentation of the medical record, of the health information, so they adapted it, and if a patient requested to be included in the special custody modules (three patients in the entire history of SERGAS), they informed them of what their inclusion entailed and included the entire complete medical record.

They indicate that:

"In case of exercising, the steps we would follow after receiving the request via registration would be:

1. Response to said request informing them of the possible healthcare risks that may arise from the limitations in accessing the EHR by enabling said module. 2. In the event that the patient indicates that they understand the risks, the information would be requested, among other information, authorization from the professionals, etc. 3. The configuration of the user for the special custody module is carried out by an administrator with user configuration privileges."

On the other hand, this system of special custody modules limits access to healthcare activity only to expressly authorized professionals, and they state that:

"Access authorizations are nominal. By default, no one can access the information contained in the medical record/module, and if necessary for the patient's healthcare, the management of the corresponding area will enable the access."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/11

access to the involved professionals. In the event that such authorization for access to these histories/modules is not available, when a user attempts to access them, the system alerts to the existence of protection mechanisms, denies access, and indicates that express authorization is required. This access is always linked to the healthcare activity.

On the other hand, for other purposes permitted under Law 41/2002, of November 14, which regulates the autonomy of the patient and rights and obligations regarding information and clinical documentation, it is also indicated that express authorization would be required.

Furthermore, access to these modules is through IANUS, which is the management program for the clinical history of SERGAS, with all security measures and system controls, plus specific permission for this purpose (there is no specific procedure because only three users have requested it, so they use the common system by increasing access privileges).

"Once a user has accessed IANUS, they CANNOT consult the data of a patient in a specially protected module unless they have specific permission for it. In fact, when searching for a user included in the specially protected module, it will only display their data to authorized professionals; other professionals will not receive any response regarding this. Once accessed, they will have access to all the information contained in the clinical history. We reiterate, as in the previous report we sent regarding this file, that experience shows us the necessity for access to electronic health records (HCE) to be complete to ensure adequate healthcare for patients."

Therefore, based on the indications in the previous paragraphs, no evidence has been found that substantiates the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

Thus, as it has not been possible to attribute responsibility for the processing as indicated, by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO PROCEED TO FILE the present proceedings.

SECOND: TO NOTIFY this resolution to the GALICIAN HEALTH SERVICE (SERGAS) and to the complaining party.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as prescribed by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and in paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/11